DOCUMENTO DE CÁTEDRA N°17

TEMA: DOCTRINA DE SEGURIDAD OT: ANÁLISIS DE RIESGOS Y LA INVERSIÓN DE LA TRÍADA CIA A AIC

Apertura: Aurora — el generador que se destruyó a sí mismo en tres segundos

En marzo de 2007, en las instalaciones del Idaho National Laboratory (INL), un equipo de investigadores del Departamento de Energía de Estados Unidos ejecutó un experimento que cambiaría permanentemente la doctrina de seguridad de los sistemas de control industrial. El experimento, conocido como Aurora Generator Test, demostró que un comando de control —técnicamente válido, sin malware, sin exploit de software— podía destruir físicamente un generador diesel de varias toneladas en menos de tres segundos.

El mecanismo no requería sofisticación técnica extraordinaria: bastaba con manipular remotamente la apertura y cierre de un interruptor (breaker) que conecta el generador a la red eléctrica, haciéndolo operar fuera de sincronía con la frecuencia de la red. El generador, al reconectarse fuera de fase, sufrió esfuerzos mecánicos y eléctricos que el diseño no contemplaba: el video clasificado posteriormente desclasificado por el Department of Homeland Security muestra al generador sacudiéndose violentamente, humeando y quedando destruido de forma irreversible.

Lo que el experimento Aurora reveló no fue una vulnerabilidad de software parcheable. Reveló que la integridad de un comando de control —su corrección técnica respecto al protocolo, independientemente de si es apropiado para el estado físico del proceso— puede ser el vector de un daño catastrófico e irreversible. Un comando de apertura de breaker es, en términos de Modbus o DNP3, una operación perfectamente legítima. El problema no es la sintaxis del comando: es el momento y el contexto físico en el que se ejecuta.

Aurora estableció la premisa doctrinal central de este documento: en los sistemas OT, la pregunta de seguridad relevante no es «este comando, ¿es auténtico?» sino «este comando, ¿es seguro ejecutarlo ahora, sobre este proceso físico, en este estado?». Esa pregunta no puede responderse con los marcos de la seguridad de la información tradicional. Requiere una doctrina propia: la inversión de la tríada CIA a AIC, una metodología de análisis de riesgo centrada en la consecuencia física, y una ingeniería que no asume que toda intrusión puede prevenirse, sino que diseña el sistema para que ninguna intrusión, exitosa o no, pueda producir un daño inaceptable.

Ubicación en el Programa: Este Documento N°17 es el tercero de la Unidad 4. Los Documentos N°15 y N°16 construyeron el mapa técnico de la convergencia IT/OT —el Modelo Purdue, sus vectores de erosión, la Industria 4.0 y el ecosistema IoT/IIoT con sus protocolos ligeros—. Este documento da el paso doctrinal: establece el marco de análisis de riesgo que permite priorizar esos hallazgos técnicos según su consecuencia real sobre la misión y la seguridad física. El Documento N°18, que cierra la Unidad 4 y

la materia, aplicará este marco de análisis de riesgo al estudio forense de Stuxnet e Industroyer: los dos casos históricos que validan empíricamente la doctrina aquí desarrollada.

OBJETIVOS DE APRENDIZAJE

- Explicar la inversión de la tríada CIA a AIC en entornos OT, justificando el cambio de prioridad de cada propiedad de seguridad con ejemplos concretos de consecuencia física.
- Aplicar la fórmula de riesgo (Amenaza × Vulnerabilidad × Consecuencia) y la matriz de riesgo probabilidad/consecuencia para clasificar hallazgos técnicos de los Documentos N°15 y N°16 según su nivel de riesgo real.
- Clasificar las consecuencias de un incidente OT según las categorías de severidad (seguridad humana, ambiental, operacional/misión, financiera, reputacional) y determinar cuál es crítica para la doctrina de Defensa.
- Analizar la metodología de Cyber-Informed Engineering (CIE) y su antecesor Consequence-driven Cyber-informed Engineering (CCE) del Idaho National Laboratory, aplicando sus cuatro fases a un sistema crítico hipotético.
- Distinguir el criterio ALARP (As Low As Reasonably Practicable) de aceptación de riesgo y asignar responsabilidad de decisión según el nivel de riesgo residual, en línea con la función Govern del NIST CSF 2.0.

1. LA INVERSIÓN DE LA TRÍADA: DE CIA A AIC

1.1. Por qué invertir la tríada no es solo reordenar tres letras

La tríada CIA —Confidencialidad, Integridad, Disponibilidad, en ese orden de prioridad— es el marco fundacional de la seguridad de la información desde la década de 1970. En un sistema IT típico, la confidencialidad ocupa el primer lugar: el dato de una transacción bancaria o un historial clínico tiene valor precisamente porque es secreto, y su exposición no autorizada es la catástrofe que el modelo de amenazas busca prevenir. La disponibilidad, en cambio, tolera degradación: un servidor web puede estar caído durante una ventana de mantenimiento sin que eso constituya, por sí mismo, un incidente de seguridad grave.

En los entornos OT, el orden se invierte: Disponibilidad, Integridad, Confidencialidad (AIC). La razón no es una preferencia operativa: es que el activo protegido no es información, es un proceso físico en ejecución continua. La Sección introductoria del programa de esta materia ya estableció esta distinción: en Ciberdefensa aplicada a OT, la prioridad es la vida humana y la integridad física de las instalaciones, no la confidencialidad de los datos. El caso Aurora de la apertura cuantifica esa premisa: la ejecución de un comando técnicamente «auténtico» pero físicamente inadecuado destruyó un activo de varias toneladas en segundos. Ningún dato fue robado. Ninguna confidencialidad fue violada. El incidente fue, sin embargo, catastrófico.

Posición	Prioridad en IT (CIA)	Prioridad en OT (AIC)	Consecuencia de invertir esta posición
1ª prioridad	Confidencialidad: proteger los datos de exposición no autorizada es el objetivo central. Una brecha de datos es la catástrofe de referencia.	Disponibilidad: el proceso físico debe seguir funcionando. Una interrupción no planificada tiene consecuencia física inmediata sobre la misión y, potencialmente, sobre la vida humana.	Un control de seguridad que prioriza la confidencialidad por sobre la disponibilidad —por ejemplo, bloquear todo el tráfico ante una alerta de falso positivo— puede causar más daño que el incidente que pretendía prevenir.
2ª prioridad	Integridad: garantizar que los datos no sean alterados sin autorización durante el tránsito o almacenamiento.	Integridad: los comandos de control y las mediciones de proceso deben reflejar fielmente el estado real, sin alteración. Aurora demuestra que un comando «auténtico» pero descontextualizado puede ser tan destructivo como uno falsificado.	La integridad ocupa la misma posición relativa en ambas tríadas, pero su definición cambia: en OT no basta con que el comando no haya sido alterado en tránsito; debe además ser apropiado para el estado físico del proceso en ese instante.
3ª prioridad	Disponibilidad: los sistemas deben ser accesibles, pero se tolera downtime planificado para mantenimiento o actualizaciones de seguridad.	Confidencialidad: proteger los datos del proceso (setpoints, telemetría, configuración) es deseable y reduce el riesgo de reconocimiento de un adversario, pero es secundaria frente a mantener el proceso físico operando con seguridad.	Esta es la inversión más contraintuitiva para un profesional formado en IT: cifrar exhaustivamente el tráfico Modbus a costa de añadir latencia que retrase la respuesta de un lazo de control crítico puede ser una decisión de seguridad incorrecta en OT.

La inversión AIC no es exclusiva de OT: es la consecuencia directa de un principio más general llamado Safety vs. Security. La seguridad funcional (Safety) protege la vida humana y la integridad física de las instalaciones; la seguridad de la información (Security) protege la confidencialidad, integridad y disponibilidad de los datos y sistemas. En IT, Security es el dominio principal y Safety apenas aparece. En OT, Safety es la consideración dominante, y la tríada AIC es la traducción de Security al lenguaje de prioridades que Safety exige.

Nota de Ciberdefensa — Aurora revisitado: por qué un firewall perfecto no habría evitado la destrucción del generador

El experimento Aurora es el caso de estudio más citado en la literatura de seguridad OT precisamente porque desafa la intuición de la seguridad de la información tradicional. Un firewall perfecto, una autenticación robusta y un cifrado de extremo a extremo habrían impedido que un adversario externo enviara el comando. Pero si el comando provino de un operador legítimo con credenciales válidas —por error humano, por una secuencia de mantenimiento mal diseñada, o por un insider malicioso, como en el caso Maroochy que se analiza en la Sección 2—, ningún control de Security lo habría detenido.

La lección doctrinal no es que la autenticación y el cifrado sean inservibles en OT: son necesarios para impedir el acceso no autorizado, que es la mayoría de los escenarios de amenaza. La lección es que la Security por sí sola no es suficiente cuando el riesgo proviene de un comando técnicamente legítimo ejecutado en el momento equivocado. La contramedida real ante el escenario Aurora no es de Security sino de ingeniería: un relé de protección de sincronía de fase (sync-check relay) que bloquee mecánicamente la reconexión del generador si la frecuencia no coincide con la de la red, independientemente de quién o qué sistema envió el comando de cierre del breaker.

Este es el primer indicio de la doctrina que la Sección 3 de este documento desarrollará en profundidad: el pensamiento basado en consecuencias (Cyber-Informed Engineering) no pregunta «cómo evito que el adversario envíe el comando» sino «cómo diseño el sistema para que ese comando, aunque se envíe, no pueda producir el daño catastrófico».

2. METODOLOGÍAS DE ANÁLISIS DE RIESGO EN ENTORNOS OT

2.1. La fórmula del riesgo aplicada a OT

El análisis de riesgo en cualquier dominio de seguridad parte de una fórmula conceptual común: el riesgo es función de la Amenaza, la Vulnerabilidad y la Consecuencia. Lo que cambia en OT no es la fórmula sino el peso relativo de cada componente y, sobre todo, la magnitud que puede alcanzar la Consecuencia. La Tabla siguiente define cada componente en el contexto específico de los sistemas de control industrial:

Componente	Definición	Fuente de información típica en OT	Ejemplo aplicado
Amenaza	Un actor (humano o automático) con la intención y la capacidad de explotar una vulnerabilidad. En OT incluye actores externos, insiders, y errores operativos no intencionales que producen el mismo efecto que un ataque deliberado.	Inteligencia de amenazas (Dragos, Claroty), historial de incidentes del sector, evaluación de capacidades del adversario según los Security Levels del ISA/IEC 62443 (Doc. N°15, Sección 4.2).	En el caso Aurora, la «amenaza» no fue un actor malicioso sino la demostración controlada de una capacidad técnica; en producción real, la misma amenaza podría originarse en un insider con acceso legítimo al breaker.
Vulnerabilidad	Una debilidad en el diseño, configuración u operación del sistema que permite que la amenaza se materialice. En OT, frecuentemente estructural y no remediable por parcheo (Doc. N°16, Sección 4).	Inventario de activos con CVEs conocidos, resultados de auditoría de arquitectura (Doc. N°15), análisis de protocolos sin autenticación (Modbus, DNP3, BACnet, MQTT).	La vulnerabilidad de Aurora es la ausencia de un mecanismo de protección de sincronía de fase que verifique, independientemente del comando recibido, que la reconexión es segura para el estado físico del generador.

Componente	Definición	Fuente de información típica en OT	Ejemplo aplicado
Consecuencia	El impacto resultante si la amenaza explota la vulnerabilidad. En OT, la consecuencia puede incluir destrucción física irreversible, pérdida de vida humana o daño ambiental, además de las consecuencias financieras y operacionales comunes a IT.	Análisis de ingeniería del proceso físico controlado, estudios de Cyber-Informed Engineering (Sección 3), evaluación de criticidad del activo para la misión.	La consecuencia de Aurora fue la destrucción irreversible del generador en menos de tres segundos: un daño que ningún parche de software puede revertir y que en un escenario real podría dejar sin energía crítica a una instalación militar.

La asimetría clave entre IT y OT es que en OT la Consecuencia puede ser irreversible y física, mientras que en IT la consecuencia típica —pérdida o exposición de datos— es, en la mayoría de los casos, reversible mediante restauración de backups o notificación regulatoria. Esta asimetría es la razón por la que el análisis de riesgo OT no puede limitarse a estimar probabilidad: debe ponderar fuertemente la magnitud de la consecuencia, incluso cuando su probabilidad es baja.

2.2. La matriz de riesgo: probabilidad × consecuencia

La herramienta operativa más utilizada para traducir la fórmula del riesgo en una decisión de gestión es la matriz de riesgo, que cruza la probabilidad de ocurrencia con la severidad de la consecuencia para asignar un nivel de riesgo. La metodología de evaluación de riesgo del ISA/IEC 62443-3-2 (referenciada en el Doc. N°15, Sección 4.2, para la definición de Security Zones) se apoya en una lógica equivalente para determinar el Security Level objetivo de cada zona:

Probabilidad \ Consecuencia	Insignificante	Menor	Mayor	Catastrófica
Improbable	**BAJO**	**BAJO**	**MEDIO**	**ALTO**
Posible	**BAJO**	**MEDIO**	**ALTO**	**EXTREMO**
Probable	**MEDIO**	**ALTO**	**EXTREMO**	**EXTREMO**
Casi certera	**MEDIO**	**ALTO**	**EXTREMO**	**EXTREMO**

La asimetría AIC se expresa visualmente en esta matriz: un evento de probabilidad «improbable» pero consecuencia «catastrófica» —exactamente el perfil de Aurora o de un ataque tipo Stuxnet, que se analizará en el Doc. N°18— alcanza nivel ALTO, no BAJO. Un modelo de riesgo de IT que ponderara solo la probabilidad subestimaría sistemáticamente estos escenarios de baja frecuencia y alto impacto, que son precisamente los que la doctrina de Ciberdefensa OT debe priorizar.

2.3. Categorías de consecuencia en infraestructura crítica y Defensa

La columna «Consecuencia» de la matriz de riesgo no es un valor único: en entornos OT de infraestructura crítica y Defensa, la consecuencia debe evaluarse simultáneamente en múltiples categorías, porque un mismo incidente puede ser insignificante en una categoría y catastrófico en otra:

Categoría	Definición	Ejemplo en infraestructura crítica / Defensa	Indicador de severidad catastrófica
Seguridad humana (Safety)	Pérdida de vida o lesión grave a personas, ya sea personal de la instalación, población civil o personal militar.	Falla del sistema de enclavamiento ferroviario (Doc. N°14) o del Vital Safety Computer que permita la colisión de dos formaciones.	Cualquier escenario con probabilidad no nula de fatalidad se considera automáticamente de consecuencia catastrófica, independientemente de su probabilidad estimada.
Ambiental	Daño al entorno natural: derrame, contaminación de cuerpos de agua, liberación de sustancias peligrosas.	Manipulación maliciosa de las válvulas de una planta de tratamiento de agua o de un sistema de contención de combustible en una base militar.	Daño irreversible al ecosistema o que requiere remediación de más de un año se clasifica como catastrófico.
Operacional / Misión	Pérdida de la capacidad operativa de la instalación para cumplir su función asignada en el tiempo requerido.	Pérdida de energía crítica en una sala de Comando y Control (Doc. N°15, caso Base Logística Sur) durante una operación militar activa.	Indisponibilidad de una capacidad crítica durante una ventana operacional sin redundancia disponible se considera catastrófica.
Financiera	Costo directo de reparación, reemplazo de activos, multas regulatorias o pérdida de producción.	Reemplazo de un transformador de subestación destruido por un ataque tipo Aurora; costo estimado de varios millones de dólares y meses de fabricación.	Costo que supera el presupuesto de contingencia anual de la instalación o que no puede ser absorbido sin afectar otras operaciones.
Reputacional / Estratégica	Pérdida de confianza pública, de aliados o de la cadena de mando en la capacidad de la organización de proteger sus activos críticos.	Divulgación pública de que una instalación militar fue comprometida mediante un vector OT no gestionado (ej. BMS, como en el caso Target del Doc. N°14).	Impacto que compromete la credibilidad operacional de la instalación ante aliados o adversarios se considera de severidad estratégica.

Nota de Ciberdefensa — Maroochy Water Services (2000): el insider que demuestra por qué el riesgo OT no es solo externo

En enero de 2000, Vitek Boden, ex contratista de la empresa instaladora del sistema SCADA de Maroochy Shire Council (Queensland, Australia), usó equipo de radio robado y software de configuración para acceder remotamente al sistema de control de las estaciones de bombeo de aguas residuales de la región. Durante varios meses, Boden emitió comandos no autorizados que detuvieron bombas, desactivaron alarmas y alteraron configuraciones, provocando el derrame de aproximadamente 800.000 litros de aguas residuales sin tratar a parques, ríos y terrenos costeros.

El caso Maroochy es el ejemplo paradigmático de un riesgo OT que ninguna defensa perimetral de IT hubiera mitigado: el adversario tenía conocimiento legítimo previo del sistema, no necesitó explotar ninguna vulnerabilidad de software, y usó protocolos de radio que el sistema no autenticaba. Aplicando la matriz de riesgo de la Sección 2.2: la probabilidad de un insider con conocimiento del sistema y motivación de venganza no es despreciable en ningún entorno OT, y la consecuencia combinó las categorías Ambiental (derrame de aguas residuales) y Reputacional (pérdida de confianza pública en la gestión del servicio).

La lección para instalaciones de Defensa es directa: el modelo de amenazas OT debe incluir explícitamente al personal con acceso legítimo previo —contratistas, ex empleados, personal en proceso de baja— como una fuente de amenaza con probabilidad propia, evaluada independientemente del modelo de amenazas externas. La revocación de credenciales y el monitoreo de accesos remotos tras la finalización de un contrato no es un control administrativo secundario: es una mitigación directa del escenario de riesgo más probable según la evidencia histórica disponible.

3. PENSAMIENTO BASADO EN CONSECUENCIAS: CYBER-INFORMED ENGINEERING (CIE)

El experimento Aurora catalizó un cambio doctrinal en la comunidad de seguridad OT que el Idaho National Laboratory formalizó progresivamente en la metodología conocida como Consequence-driven Cyber-informed Engineering (CCE), luego ampliada por el Departamento de Energía de EE. UU. a la estrategia más amplia de Cyber-Informed Engineering (CIE, 2022). La premisa central es un cambio de pregunta: en lugar de preguntar «¿cómo evito que el adversario obtenga acceso?» —una pregunta que la experiencia demuestra que nunca puede responderse con certeza absoluta—, la metodología pregunta «¿cuáles son los eventos de consecuencia más catastrófica que este sistema podría sufrir, y cómo rediseño la ingeniería para que ningún acceso, autorizado o no, pueda producirlos?».

Fase	Objetivo	Pregunta clave que responde	Resultado / output
1. Priorización de consecuencias	Identificar los eventos de máxima consecuencia que la organización no puede tolerar bajo ninguna circunstancia, independientemente de su origen (cibernético, mecánico, humano).	Si este sistema fallara de la peor forma posible, ¿qué sucede? ¿Cuál es el evento que pondría en riesgo la misión, la vida humana o la continuidad operacional de forma irreversible?	Lista priorizada de eventos de consecuencia inaceptable (ej.: «pérdida total de energía en la sala de comunicaciones durante una operación activa»).

Fase	Objetivo	Pregunta clave que responde	Resultado / output
2. Análisis de sistema de sistemas	Mapear todos los caminos técnicos —digitales, físicos, humanos— que podrían converger en cada evento de consecuencia priorizado, incluyendo rutas que el modelo de amenazas convencional no consideraría.	¿Qué combinación de accesos, comandos o fallas —cibernéticas o no— podría producir este evento? ¿Qué vectores de convergencia IT/OT (Doc. N°15) participan en esa cadena?	Mapa de rutas de ataque y falla que conducen al evento, incluyendo combinaciones de múltiples vectores de erosión de la Sección 1.2 del Doc. N°15.
3. Focalización basada en consecuencias	Priorizar los recursos de ingeniería y seguridad en los puntos de la cadena identificada cuya eliminación o mitigación reduce el mayor número de rutas hacia el evento catastrófico.	De todos los puntos de la cadena, ¿cuál es el más eficiente de proteger? ¿Dónde una sola intervención de ingeniería rompe múltiples rutas simultáneamente?	Lista de puntos críticos de intervención ordenados por costo-beneficio en reducción de riesgo.
4. Mitigaciones y protecciones	Implementar controles de ingeniería —preferentemente independientes del estado cibernético del sistema— que eliminen la capacidad física de producir el evento catastrófico, en lugar de depender exclusivamente de controles de Security.	¿Qué mecanismo de ingeniería —mecánico, analógico, de redundancia física— puede garantizar que el evento no ocurra, incluso si todos los controles digitales fallan o son evadidos?	Controles de ingeniería implementados (ej.: relé de sincronía de fase de protección mecánica en el caso Aurora) y validados independientemente del estado de la red.

El punto distintivo de la Fase 4 es la preferencia por controles de ingeniería sobre controles de Security pura. Un control de Security —autenticación, cifrado, segmentación— reduce la probabilidad de que un adversario alcance el punto de decisión, pero no elimina la consecuencia si ese punto se alcanza por cualquier vía, incluyendo el error humano o el insider. Un control de ingeniería —un interlock mecánico, un límite físico de válvula, un relé de protección analógico independiente de la red digital— elimina la capacidad física de producir el daño, independientemente de quién o qué origina el comando.

Nota de Ciberdefensa — Ingeniería para Defensa: el override manual como control CCE de Fase 4

Las instalaciones de Defensa tienen una ventaja doctrinal histórica para la aplicación de Cyber-Informed Engineering: muchos sistemas militares críticos —sistemas de armas, control de incendios, generación de emergencia— fueron diseñados originalmente con redundancia analógica y mecanismos de override manual independientes del sistema de control digital,

precisamente porque la doctrina militar clásica nunca asumió que el sistema digital estaría siempre disponible o sería siempre confiable.

El riesgo de la convergencia IT/OT analizada en el Doc. N°15 es que la modernización tecnológica frecuentemente elimina esos overrides analógicos en nombre de la eficiencia operativa, sin una evaluación CCE explícita de la consecuencia de esa eliminación. Un generador de emergencia con override manual de sincronización requiere que un operador verifique físicamente la sincronía de fase antes de autorizar el cierre del breaker: ese paso humano, aunque más lento que la automatización digital, es exactamente el control que habría impedido el escenario Aurora.

La recomendación doctrinal para cualquier proyecto de modernización OT en instalaciones de Defensa es aplicar la Fase 1 de CCE (priorización de consecuencias) antes de aprobar la eliminación de cualquier mecanismo analógico o manual existente. Si el evento que ese mecanismo prevendría está en la lista de consecuencias catastróficas inaceptables, su eliminación requiere una mitigación de ingeniería equivalente, no solo un control de Security adicional.

4. ACEPTACIÓN DE RIESGO, RIESGO RESIDUAL Y GOBERNANZA DE LA DECISIÓN

Ningún sistema OT puede reducirse a riesgo cero: incluso después de aplicar segmentación (Doc. N°15), controles compensatorios (Doc. N°16) e ingeniería basada en consecuencias (Sección 3), persiste un riesgo residual. La doctrina de gestión de riesgo establece el criterio ALARP —As Low As Reasonably Practicable— como estándar de decisión: el riesgo debe reducirse hasta el punto en que el costo adicional de mitigación supera el beneficio marginal de reducción de riesgo obtenido.

El criterio ALARP no es una excusa para la inacción: exige documentar explícitamente por qué un riesgo residual se considera aceptable, quién lo acepta formalmente, y bajo qué condiciones esa aceptación debe revisarse. Esta es la función Govern del NIST CSF 2.0, mencionada en el Doc. N°15 (Sección 4.1) como la sexta función que define el contexto organizacional y las responsabilidades de decisión. En entornos de Defensa, esta gobernanza se articula frecuentemente mediante un marco de acreditación formal —análogo al Risk Management Framework (RMF) y la Authority to Operate (ATO) usados en sistemas gubernamentales— donde una autoridad designada acepta explícitamente el riesgo residual antes de autorizar la operación del sistema.

Nivel de riesgo (matriz Sección 2.2)	Acción requerida según criterio ALARP	Responsable de la aceptación formal	Frecuencia de revisión del riesgo aceptado
BAJO	Aceptable sin mitigación adicional. Documentar en el registro de riesgos (risk register) para trazabilidad, sin requerir acción inmediata.	Responsable técnico del sistema (ingeniero de planta, administrador OT).	Revisión anual o ante cambio significativo de arquitectura.
MEDIO	Mitigar cuando sea operativamente viable,	Jefe de sección de Ciberdefensa o	Revisión semestral o ante cualquier

Nivel de riesgo (matriz Sección 2.2)	Acción requerida según criterio ALARP	Responsable de la aceptación formal	Frecuencia de revisión del riesgo aceptado
	dentro del ciclo normal de mantenimiento. No requiere detener la operación para remediar de inmediato.	responsable de seguridad OT de la instalación.	cambio en el perfil de amenaza (nuevo CVE, nuevo vector de convergencia).
ALTO	Mitigar en el corto plazo con controles compensatorios inmediatos (Doc. N°16, Sección 4) mientras se planifica la solución definitiva. Requiere plan de remediación documentado con plazo.	Comandante o director de la instalación, con asesoramiento técnico formal del equipo de Ciberdefensa.	Revisión trimestral hasta la reducción del riesgo a nivel MEDIO o BAJO.
EXTREMO	Acción inmediata obligatoria: aislamiento, segmentación de emergencia o suspensión de la función afectada hasta que el riesgo se reduzca. No es ALARP-aceptable mantener la operación sin mitigación inmediata.	Autoridad de mayor nivel de la cadena de mando aplicable (análogo a la Authority to Operate —ATO— del marco RMF).	Revisión continua hasta confirmación de reducción de nivel; reporte inmediato a la cadena de mando.

La decisión de Colonial Pipeline de apagar preventivamente el oleoducto (Doc. N°15, Apertura) es interpretable bajo este marco: ante la incertidumbre sobre el estado real de segmentación del OT durante el incidente de ransomware, la organización no podía clasificar el riesgo residual con confianza —la condición previa indispensable para aplicar ALARP—, y la única acción consistente con un nivel de riesgo no clasificable es tratarlo como EXTREMO por precaución. Una arquitectura con segmentación verificable habría permitido clasificar el riesgo real —probablemente BAJO o MEDIO— y aplicar una acción proporcional, evitando el apagado total.

5. ACTIVIDADES DE VERIFICACIÓN Y ANÁLISIS

1. Aplicación de la tríada AIC a un escenario de Base Logística Sur

Retome la arquitectura de Base Logística Sur del AP N°15 (BMS, generadores de emergencia, sensores IIoT de mantenimiento predictivo). Analice el sistema de control de los generadores de emergencia bajo el marco AIC de este documento.

(a) Para cada propiedad de la tríada AIC (Disponibilidad, Integridad, Confidencialidad), describa qué significaría concretamente una falla de esa propiedad en el sistema de control de los generadores, indicando la consecuencia física esperada.

(b) Identifique si el escenario Aurora (apertura de breaker fuera de sincronía) es aplicable a este sistema. Si los generadores no se sincronizan con una red eléctrica externa, ¿qué evento equivalente de Integridad podría producir consecuencia física catastrófica?

(c) Justifique, con referencia explícita a la Sección 1.1, por qué priorizar la confidencialidad de los datos de telemetría de estos generadores por sobre su disponibilidad sería una decisión de seguridad incorrecta en este contexto.

2. Clasificación de riesgo — vulnerabilidad URGENT/11 en la matriz probabilidad/consecuencia

El Documento N°16 (Sección 4) describe el caso URGENT/11: vulnerabilidades críticas en VxWorks RTOS sin parche disponible, afectando PLCs Siemens en producción activa. Suponga una instalación de Defensa con tres PLCs afectados que controlan válvulas de un sistema de combustible.

(a) Estime la probabilidad (Improbable / Posible / Probable / Casi certera) de que esta vulnerabilidad sea explotada, justificando con el perfil de adversario del Security Level correspondiente (Doc. N°15, Sección 4.2).

(b) Clasifique la consecuencia (Insignificante / Menor / Mayor / Catastrófica) en al menos dos de las categorías de la Tabla de la Sección 2.3, justificando la elección con el proceso físico controlado (válvulas de combustible).

(c) Ubique el riesgo resultante en la matriz de la Sección 2.2 y, aplicando la Tabla ALARP de la Sección 4, determine qué acción es obligatoria, quién debe aceptar formalmente el riesgo residual, y con qué frecuencia debe revisarse.

3. Aplicación de las cuatro fases de Cyber-Informed Engineering a un sistema crítico militar

Una instalación militar de almacenamiento de combustible tiene un sistema SCADA que controla las válvulas de carga y descarga de los tanques. El sistema fue modernizado recientemente con un gateway IIoT (similar al Doc. N°16) que permite monitoreo remoto del nivel de combustible.

(a) Fase 1 (Priorización de consecuencias): identifique el evento de consecuencia más catastrófica que este sistema podría sufrir, indicando en qué categoría o categorías de la Tabla de la Sección 2.3 se clasifica.

(b) Fase 2 (Análisis de sistema de sistemas): trace al menos dos rutas distintas — una cibernética a través del gateway IIoT, otra a través de un vector de convergencia del Doc. N°15— que podrían converger en el evento identificado en (a).

(c) Fases 3 y 4 (Focalización y mitigaciones): proponga un control de ingeniería — mecánico o analógico, independiente del estado cibernético del sistema— que elimine la capacidad física de producir el evento catastrófico, incluso si ambas rutas identificadas en (b) son comprometidas simultáneamente.

4. Caso integrador — Colonial Pipeline reanalizado bajo el marco ALARP

Retome el caso Colonial Pipeline (Doc. N°15, Apertura). Aplique el marco de aceptación de riesgo de la Sección 4 de este documento para evaluar la decisión de apagado preventivo del oleoducto.

(a) Explique por qué la incertidumbre sobre el estado de segmentación del OT impidió clasificar el riesgo en la matriz de la Sección 2.2 en el momento del incidente. ¿Qué información faltante habría sido necesaria para una clasificación precisa?

(b) Argumente por qué tratar un riesgo no clasificable como EXTREMO es consistente con el criterio ALARP, aun cuando el riesgo real (una vez conocido con certeza) podría haber sido BAJO o MEDIO.

(c) Diseñe la arquitectura de monitoreo mínima —combinando los controles del Doc. N°15 (DMZ 3.5, segmentación) con los principios de Cyber-Informed Engineering de la Sección 3 de este documento— que habría permitido a Colonial Pipeline clasificar el riesgo con confianza durante el incidente y evitar el apagado total del oleoducto.

6. GLOSARIO MÍNIMO

Término	Definición
AIC (tríada)	Disponibilidad, Integridad, Confidencialidad, en ese orden de prioridad. Inversión de la tríada CIA tradicional de IT, aplicada a entornos OT donde la interrupción del proceso físico tiene consecuencia inmediata sobre la misión y la seguridad humana.
ALARP (As Low As Reasonably Practicable)	Criterio de aceptación de riesgo que exige reducir el riesgo hasta el punto en que el costo adicional de mitigación supera el beneficio marginal obtenido. Requiere documentación explícita de quién acepta el riesgo residual y bajo qué condiciones debe revisarse.
Aurora Generator Test	Experimento realizado por el Idaho National Laboratory en marzo de 2007 que demostró la destrucción física de un generador diesel mediante manipulación remota de la apertura/cierre de un breaker, provocando reconexión fuera de sincronía de fase con la red eléctrica.
Authority to Operate (ATO)	Autorización formal emitida por una autoridad designada para operar un sistema, aceptando explícitamente el riesgo residual identificado. Concepto central del Risk Management Framework (RMF, NIST SP 800-37) usado en sistemas gubernamentales y de Defensa.
CCE (Consequence-driven Cyber-informed Engineering)	Metodología del Idaho National Laboratory que identifica los eventos de consecuencia más catastrófica de un sistema y diseña mitigaciones de ingeniería —preferentemente independientes del estado cibernético— para eliminar la capacidad física de que ocurran. Antecesora de la estrategia más amplia CIE (2022).
Consecuencia	Impacto resultante si una amenaza explota una vulnerabilidad. En OT incluye categorías de severidad física, ambiental, operacional/misión, financiera y reputacional, frecuentemente irreversibles.
Govern (NIST CSF 2.0)	Sexta función del NIST Cybersecurity Framework 2.0 que establece el contexto organizacional, roles y responsabilidades de decisión sobre el riesgo, incluyendo quién tiene autoridad para aceptar riesgo residual.
Maroochy Water Services (caso)	Incidente de enero de 2000 en Queensland, Australia, donde un insider con conocimiento previo del sistema SCADA causó el derrame de aproximadamente 800.000 litros de aguas residuales mediante manipulación remota de estaciones de bombeo, sin explotar vulnerabilidad de software alguna.
Matriz de riesgo	Herramienta de gestión que cruza la probabilidad de ocurrencia de un evento con la severidad de su consecuencia para asignar un

Término	Definición
	nivel de riesgo (Bajo, Medio, Alto, Extremo) que orienta la acción requerida.
Riesgo residual	Nivel de riesgo que permanece después de aplicar todos los controles de mitigación razonablemente practicables. Nunca es cero en sistemas OT complejos; debe ser aceptado formalmente por una autoridad con responsabilidad proporcional a su magnitud.
Safety vs. Security	Distinción doctrinal entre la seguridad funcional (Safety: protección de la vida humana e integridad física) y la seguridad de la información (Security: confidencialidad, integridad y disponibilidad de datos y sistemas). La tríada AIC es la traducción de Security a las prioridades que Safety exige en entornos OT.
Sync-check relay (relé de verificación de sincronía)	Dispositivo de protección eléctrica que bloquea mecánicamente el cierre de un breaker si la frecuencia y fase del generador no coinciden con las de la red, independientemente del comando recibido. Control de ingeniería que habría prevenido el escenario Aurora.

REFERENCIAS BIBLIOGRÁFICAS

Stouffer, K., et al. (2023). Guide to Operational Technology (OT) Security (NIST SP 800-82 Revision 3). NIST. Sección 3: ICS Risk Management and Assessment.

International Society of Automation. (2018). ISA/IEC 62443-3-2: Security Risk Assessment for System Design. ISA/IEC.

Bochman, A., & Freeman, S. (2021). Countering Cyber Sabotage: Introducing Consequence-Driven, Cyber-Informed Engineering (CCE). CRC Press.

U.S. Department of Energy. (2022). National Cyber-Informed Engineering Strategy. Office of Cybersecurity, Energy Security, and Emergency Response (CESER).

Idaho National Laboratory. (2016). Cyber-Informed Engineering: The Need for a New Risk Informed and Design Methodology. INL/EXT-16-40099.

Slay, J., & Miller, M. (2007). Lessons Learned from the Maroochy Water Breach. En Critical Infrastructure Protection (IFIP International Federation for Information Processing, Vol. 253). Springer.

NIST. (2018). Risk Management Framework for Information Systems and Organizations (NIST SP 800-37 Revision 2). National Institute of Standards and Technology.

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security (2da ed.). Syngress. Capítulo 1: Introduction; Sección: Risk Assessment.

Cátedra Tecnología Operativa (2026). Documentos de Cátedra N°15 (Convergencia IT/OT) y N°16 (IoT e IIoT). FADENA.